

Recommandations RGPD¹

Interlocuteurs « Dev'Immédiat »:

- Clara Daucour, directrice générale
- Jean-Luc, DPO, Data Protection Officer /DPD, Délégué à la Protection des Données
- Salomé SAQUE, responsable de la base client

Livrables associés à la mission :

- Extraction CRM² anonymisée
- Rapport de documentation des traitements

Cadre RGPD :

Le Règlement Général sur la Protection des Données (RGPD) est une réglementation européenne entrée en vigueur le 25 mai 2018.

Il vise à renforcer

- Les obligations des établissements privés et publics qui traitent des données privées.
- Renforcer la protection des données à caractère personnel³ des individus au sein de l'union européenne.

Il s'organise autour de grands principes

- De finalité : Pourquoi traiter les données ?
- De licéité : Est-ce légal ?
- De proportionnalité et de pertinence : Utiliser seulement l'information nécessaire aux traitements.
- De durée de conservation : Combien de temps ?
- De sécurité et de confidentialité.
- De droits des personnes : information, limitation du traitement, accès, opposition, rectification, effacement, portabilité, directives post-mortem.

¹ Règlement Général sur la Protection des Données

² Customer Relationship Management (CRM) : Gestion de la Relation Client (GRC)

³ Une donnée personnelle est une information relative à une personne physique susceptible d'être identifiée, directement ou indirectement

Contexte :

À la suite d'une plainte déposée auprès de la CNIL⁴, l'entreprise « Dev'Immédiat » fait l'objet d'une limitation temporaire des traitements de données personnelles. Cette décision implique un encadrement renforcé des usages des données du CRM et impose une mise en conformité rapide des pratiques internes.

Dans ce cadre, le présent document vise à :

- Sécuriser immédiatement la conformité au RGPD, en appliquant les principes de minimisation, de limitation des finalités et de protection des données.
- Réduire les risques en évitant tout traitement de données personnelles non strictement nécessaire.
- Préparer les éléments justificatifs attendus par la CNIL, en vue de la levée de la limitation temporaire des traitements.

Ce document constitue ainsi un outil opérationnel de gouvernance et de sécurisation des données CRM, destiné à accompagner les équipes métier et IT dans la mise en œuvre rapide de mesures correctives adaptées.



⁴ Commission Nationale de l'Informatique et des Libertés autorité administrative indépendante française chargée de :

- Protéger les données personnelles
- Veiller au respect du RGPD et de la loi Informatique et Libertés
- Informer et accompagner les organismes
- Contrôler et sanctionner en cas de non-conformité

1. Minimisation et finalités⁵

- Geler tout champ non indispensable au pilotage commercial pour n'utiliser que les données nécessaires.
- Mettre en place une liste de variables autorisées par usage avec une notion de « whitelist » (prospection, devis, contrat) afin de limiter les finalités.
- Interdire l'export complet de la base et imposer des extractions par requêtes validées.

2. Habilitation et traçabilité

- Revoir les habilitations : accès par rôle (moindre privilège), séparation des fonctions.
- Activer une journalisation des accès/exports (qui, quoi, quand, volume) et un processus d'alerte en cas d'extraction anormale.

3. Transparence et droits des personnes⁶

- Mettre à jour les notices d'information (collecte web/CRM) : finalités, bases légales, durées, destinataires, droits (accès, effacement, opposition).
- Mettre en place un circuit de traitement des demandes (SLA, preuve de réponse).

4. Politique de conservation et purge⁷

- Définir des durées de conservation par finalité (prospection, devis, contrat) et automatiser la purge/anonymisation à échéance.
- Bloquer la création de champs « libres » sans durée de rétention associée.

5. Conditions de réussite et adhésion du collectif

L'efficacité des mesures RGPD dépend fortement de l'adhésion des équipes et des parties prenantes. Voici quelques actions recommandées :

- Pédagogie sur les risques,
- Co-construction avec le métier,
- Règles simples et visibles (whitelist, politique d'export),
- Formations courtes et suivi d'indicateurs d'adhésion.

⁵ Article 5 - Principes relatifs au traitement des données à caractère personnel

⁶ Article 13 - Informations à fournir lorsque des données à caractère personnel sont collectées auprès de la personne concernée

Article 14 - Informations à fournir lorsque les données à caractère personnel n'ont pas été collectées auprès de la personne concernée

⁷ Article 17 - Droit à l'effacement (« droit à l'oubli »)